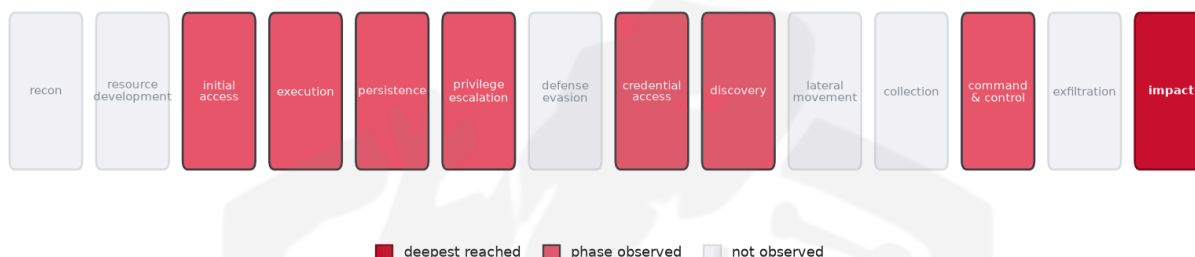


# THREAT REPORT: QILIN EXPLOITS CVE-2026-48710 TO HIJACK AI INFRASTRUCTURE

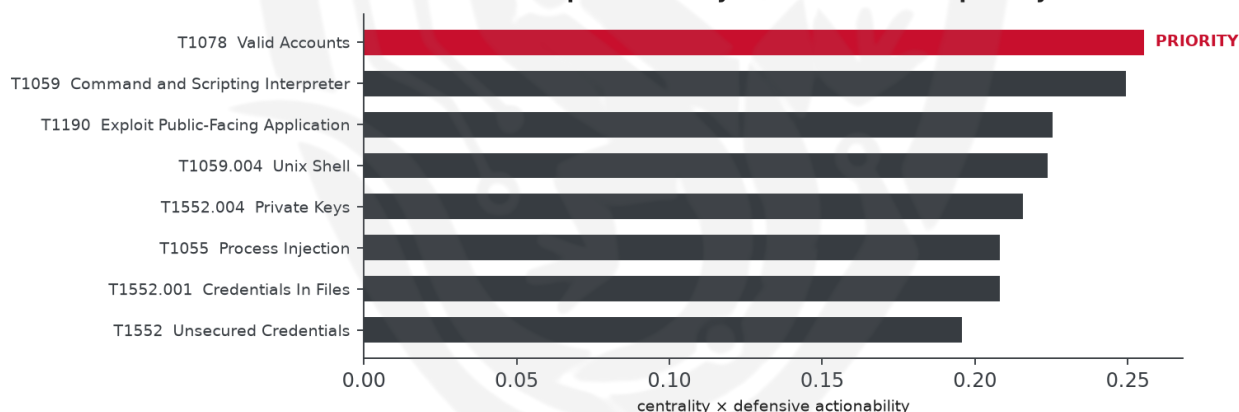
## Visual Summary

### Kill-Chain Reach — Critical (deepest phase reached: impact)



How far down the attack chain this campaign reached; deepest phase in crimson.

### Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

## Summary

The source attributes this activity to the threat actor Qilin, which is leveraging the XMRig mining malware alongside the newly disclosed CVE-2026-48710. While the specific victims are not identified, the campaign targets AI-related infrastructure. Priority should be given to enforcing multi-factor authentication on all accounts, disabling dormant or over-privileged accounts, and monitoring for impossible-travel or anomalous logons, while promptly patching CVE-2026-48710 on affected systems.

## Threat Overview

Qilin is observed deploying the XMRig cryptocurrency-mining family and exploiting the public-facing vulnerability CVE-2026-48710. The victimology remains unspecified, with no concrete information on targeted countries or sectors.

## Attack Chain and Priority Control

---

The observed activity follows a multi-stage chain:

1. **Exploit Public-Facing Application (T1190)** – attackers weaponize CVE-2026-48710 to gain initial access.
2. **Valid Accounts (T1078)** – compromised credentials are used to establish persistent footholds.
3. **Process Injection (T1055)** – malicious code is injected into legitimate processes.
4. **Command and Scripting Interpreter (T1059)** – scripts, including Python (T1059.006) and Unix shell (T1059.004), drive further actions.
5. **Masquerading (T1036 / T1036.005)** – the malware adopts legitimate resource names and locations.
6. **System Information Discovery (T1082) and File/Directory Discovery (T1083)** – gather host details.
7. **Unsecured Credentials (T1552) and Credential Dumping (T1552.001 / T1552.004)** – extract stored credentials and private keys.
8. **Ingress Tool Transfer (T1105)** – additional tools are transferred to the compromised host.
9. **DNS Application Layer (T1071.004) and General Application Layer Protocol (T1071)** – command-and-control traffic is tunneled over DNS.
10. **Resource Hijacking (T1496)** – the compromised system is repurposed for cryptocurrency mining.

**Priority technique:** T1078 Valid Accounts

**Priority control (verbatim):** Enforce MFA on all accounts; disable dormant and over-privileged accounts; alert on impossible-travel and anomalous logons. In parallel, patch CVE-2026-48710 on all affected systems.

## Infrastructure and Corroboration

---

Third-party enrichment shows the command-and-control nodes are hosted by providers Host SpA, TechTies Inc., and IP Services Sp. zo.o., as reported by the source pulse. AbuseIPDB flags none of the associated indicators at the 80 % confidence threshold, with the highest confidence observed at only 8 % (AbuseIPDB). No additional malware families were corroborated by abuse.ch.

---

## Technical Appendix

---

*Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.*

### Observed Techniques (ATT&CK, expert-tagged by source)

- T1071.004 DNS
- T1036.005 Match Legitimate Resource Name or Location
- T1082 System Information Discovery
- T1071 Application Layer Protocol
- T1190 Exploit Public-Facing Application
- T1036 Masquerading
- T1552 Unsecured Credentials
- T1055 Process Injection

- T1552.004 Private Keys
- T1059 Command and Scripting Interpreter
- T1083 File and Directory Discovery
- T1552.001 Credentials In Files
- T1059.004 Unix Shell
- T1078 Valid Accounts
- T1027 Obfuscated Files or Information
- T1059.006 Python
- T1496 Resource Hijacking
- T1518 Software Discovery
- T1105 Ingress Tool Transfer

## Analytical Scores

- Priority technique (graph chokepoint): T1078 Valid Accounts (centrality 0.2553).
- Operational risk: Critical (score 1.0, reaches impact).

## Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4867; reference threshold  $\tau = 0.6$ ).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

| Historical Profile | Behavioural Overlap |
|--------------------|---------------------|
| Rocke              | 0.4867              |
| APT18              | 0.4326              |
| TeamTNT            | 0.3709              |
| Tropic Trooper     | 0.3679              |
| Windigo            | 0.3468              |

## Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 8%.

## Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

| Type   | Indicator                              | Context                                           |
|--------|----------------------------------------|---------------------------------------------------|
| IP     | 185[.]84[.]98[.]85                     | AbuseIPDB 0% (IT) · AS47242 Host SpA              |
| IP     | 94[.]26[.]106[.]29                     | AbuseIPDB 8% (DE) · AS197170 TechTies Inc.        |
| IP     | 185[.]62[.]1[.]8                       | AbuseIPDB 0% (PL) · AS34907 IP Services Sp. zo.o. |
| Domain | crazyeltonproxy[.]top                  |                                                   |
| Domain | 1710[.]rwl[.]be                        |                                                   |
| URL    | hxxp://185[.]62[.]1[.]8/mon/mon[.]zip' |                                                   |

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

## Flame Cell // Adversary Pivot [ BETA ]

*BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? [norbert@salacti.com](mailto:norbert@salacti.com)*

- **Control applied:** T1078 Valid Accounts (initial-access)
- **Observed here:** T1078 Valid Accounts was the initial-access control point; blocking a means-of-entry rarely stops a determined actor, so the pivot projects forward to the execution stage they must still reach.
- **Projected pivot:** T1047 Windows Management Instrumentation (execution)
- **Basis:** of the 29+ groups that use Valid Accounts, this pairing runs 1.8x above base rate, a disproportionately-coupled move rather than the obvious one.

With T1078 Valid Accounts blocked, Qilin could preserve the same objective by pivoting to T1047 Windows Management Instrumentation, a technique disproportionately paired with it across tracked groups. Defensive countermeasure: Monitor wmiprvse.exe child-process creation; restrict remote WMI (DCOM) at the host firewall; enable WMI-Activity operational logging.

**Also plausible (same tactic):** T1569 System Services (n=13, lift 2.0), T1053 Scheduled Task/Job (n=31, lift 1.4)

### Detection and hardening for the pivot (T1047 Windows Management Instrumentation)

- **Telemetry:** Sysmon (WMI events); Microsoft-Windows-WMI-Activity/Operational
- **Detect:**
  - Sysmon 19/20/21 (WMI event filter/consumer/binding) for persistence
  - wmic.exe / WmiPrvSE.exe spawning shells; remote WMI process creation
  - WMI-Activity/Operational operations from unusual users/hosts
- **Harden:**
  - Restrict WMI remote access; monitor permanent WMI subscriptions

- Least-privilege; segment management protocols
- **MITRE:** M1040 Behavior Prevention, M1038 Execution Prevention, M1026 Privileged Account Management · DS0009 Process, DS0005 WMI, DS0017 Command

